Post-Quantum Cryptography Migration Manual: Seven Steps for Leaders

Scott A. Cole · Facts checked October 22, 2026

This manual shows a leader how to start a post-quantum cryptography (PQC) migration this quarter, in seven steps, without waiting for a deadline date. It is a working draft. Each fact was checked against a primary source on October 22, 2026, and the Facts status section shows how far. Anything labeled judgment is informed opinion, not a cited finding.

How to use this manual

Read it top to bottom once, then work the steps in order. Each step ends with a done-when test, so you know when to move on.

This manual is for leaders who need to get an organization moving, not for cryptographers. It uses plain words, names the standards by their official numbers, and says so when a point is judgment and not a cited finding.

Plain-language terms

Term	What it means
Public-key cryptography	Math that lets two parties who have never met set up a secret connection and prove who they are. RSA and elliptic-curve are the common types.
Key exchange	The step where two systems agree on a secret key before they exchange data.
Digital signature	A mark that proves a message or file came from a specific source and was not changed.
Certificate	A signed record that ties a public key to a name, such as a website.
Post-quantum cryptography (PQC)	New algorithms built to resist quantum attack. They run on ordinary computers.
Hybrid key exchange	A key exchange that combines a classical method and a post-quantum method in one handshake.
Passkey	A login that uses a key pair stored on your device in place of a password.
Harvest now, decrypt later	Recording encrypted traffic today in the hope of breaking it later.

The threat in plain terms

The exposure sits in the public-key layer, not in your passwords. RSA and elliptic-curve cryptography protect key exchange, digital signatures, and certificates, and a large enough quantum computer would break them.

Treat “harvest now, decrypt later” as a risk to plan for. It is a recognized threat, but no public evidence was found that it is happening at scale, so this manual does not say it is already happening.

This manual gives no deadline date. NIST’s transition timeline document (IR 8547) is still listed as an initial public draft on NIST’s own page as of today, so any 2030 or 2035 date you read elsewhere may change. Check NIST’s post-quantum cryptography project page for current guidance before you set your own schedule.

The migration is urgent because finding and replacing cryptography across an organization is slow work, and data that must stay secret for a long time is the first to be at risk. That is a judgment, not a cited finding.

Standards in place today

NIST finalized three post-quantum standards in August 2024, and each one gives August 13, 2024 as its publication and effective date.

Standard	Name	Job	Published and effective
FIPS 203	ML-KEM	Key establishment	August 13, 2024
FIPS 204	ML-DSA	Digital signatures	August 13, 2024
FIPS 205	SLH-DSA	Digital signatures (hash-based)	August 13, 2024

Cite only these final standards when you ask vendors for support.

Steps 1 to 4: find what you have

1. **Name an owner and a start date.** Assign one person with authority across IT, security, and procurement. Done when the name and date are written down.
2. **Build the inventory.** List every place RSA and elliptic-curve cryptography live: TLS certificates, VPNs, code signing, email signing, device and API keys, and vendor products. Done when each system has an owner and a listed algorithm.
3. **Rank by shelf life.** Ask how long each item's data must stay secret. Medical records, legal archives, and trade secrets rank high. Session traffic that is worthless tomorrow ranks low. Done when every item has a number of years.
4. **Move long-lived items first.** Start with the longest shelf life and the easiest fix. Done when the top ten items each have a named replacement plan.

Start the inventory with what you can see. A spreadsheet with four columns (system, owner, algorithm, years the data must stay secret) is enough for a first pass.

Worked example: a first-pass inventory

The rows below are fictional. Replace them with your own systems.

System	Owner	Algorithm in use	Years data must stay secret	Move order
Patient records sent between sites	IT	VPN with RSA key exchange	25	1
Customer contracts in an encrypted archive	Legal	RSA key wrapping	20	2
Firmware code signing	Engineering	ECDSA P-256 signatures	Not applicable	3
AI agent service tokens and signing keys	Platform	ES256 signed tokens	1	4
Public marketing site	Web	ECDSA certificate	0	5

Rank data that must stay secret first, longest shelf life on top. Rank signing items next, by how long a forged signature would do harm. That ordering rule is judgment, so adjust it to your own risk.

The example shows why step 6 matters. The agent row ranks low on shelf life, but it still belongs on the list.

Steps 5 to 7: vendors, agents, and logins

5. **Ask every vendor for a PQC plan.** Send one question: which of FIPS 203, 204, and 205 will you support, and when? Done when each critical vendor has answered in writing.
6. **Count the credentials your AI agents hold.** Every service identity, token, and signing key an AI agent holds is a

credential to migrate. Add them to the inventory from step 2. Done when each agent has a listed set of credentials and an owner.

7. **Fix logins with passkeys first.** Use passkeys wherever a service offers them. Where a passkey is not offered, use a long passphrase stored in a password manager. That fallback is the author's recommendation. Where your systems store passwords, follow NIST SP 800-63B-4, which says passwords shall be salted and hashed with a suitable password hashing scheme, using a cost factor as high as practical. Done when your top ten services use a passkey or a managed passphrase.

Be honest about what passkeys do. Passkeys stop phishing and credential theft today. They still sign with classical algorithms (WebAuthn lists ES256, RS256, and EdDSA), so they join the post-quantum migration later and do not finish it. Their weak points are the account that syncs them and the account recovery process, so protect both. That is informed judgment, not a cited finding.

Keep your AES settings. NIST's post-quantum cryptography FAQ says current applications can continue to use AES with 128, 192, or 256 bit keys, assuming no new weaknesses are found in AES. The quantum risk sits in the public-key layer.

Know what already works. Firefox offers hybrid X25519 + ML-KEM-768 key agreement by default, per Mozilla's enterprise policy reference. Chrome enabled ML-KEM by default on all platforms in a December 2024 Chromium change. No verified figure was found for how many servers support it, so this manual gives none.

For step 6: the AI agent exposure appraisal repository measures agent-side risk. Its figures come from simulated setups with small open-weight models, and its README frames them as evidence, not an audit.

What's next

This field keeps moving, so this section stays short. Proposals exist to add post-quantum signatures to passkeys. One example is an individual Internet-Draft for ML-DSA in WebAuthn (draft-vitap-ml-dsa-webauthn-04, dated March 2026), which the IETF labels work in progress and which shows an expiry date of September 24, 2026. Watch for new authentication methods, and recheck NIST's project page each quarter.

Checklist

- [ ] Name an owner and a start date
- [ ] Build the inventory of RSA and elliptic-curve use
- [ ] Record how many years each item's data must stay secret
- [ ] Pick the ten longest-lived items and name a replacement plan for each
- [ ] Send every critical vendor the FIPS 203, 204, and 205 question
- [ ] List the credentials each AI agent holds
- [ ] Move your top ten services to passkeys or managed passphrases
- [ ] Protect the sync account and account recovery for passkeys
- [ ] Recheck NIST's current guidance each quarter

Facts status and sources

Each fact below was checked on October 22, 2026. Items marked judgment are informed opinion, and items marked not included had no verifiable source.

Fact	Status	Basis
FIPS 203, 204, and 205 published and effective August 13, 2024	Verified	NIST documents. 204 and 205 opened October 22, 2026. 203 read in an earlier session.
NIST IR 8547 is still an initial public draft	Verified	NIST page, October 22, 2026. No final version shown.
NIST SP 800-63B-4 is final (July 31, 2025) and requires salted, hashed passwords with a cost factor	Verified	NIST pages
NIST says AES with 128, 192, or 256 bit keys can continue to be used	Verified	NIST post-quantum FAQ
Firefox offers hybrid X25519 + ML-KEM-768 by default	Verified	Mozilla enterprise policy reference
Chrome enabled ML-KEM by default on all platforms (December 4, 2024 change)	Verified	Chromium commit message
WebAuthn lists ES256, RS256, EdDSA	Verified in one vendor guide only	Yubico developer guide
Sync account and recovery are passkey weak points	Judgment	Not cited
Passphrase in a password manager as the passkey fallback	Judgment	Author’s recommendation
Argon2id	Not included	RFC 9106 is Informational, not Standards Track. OWASP recommends it. NIST SP 800-63B-4 does not name it.
Edge default, server adoption share, Cloudflare traffic figure	Not included	No primary source could be opened
“Harvest now, decrypt later” is happening at scale	Not claimed	No public evidence found

Sources opened for this draft

- FIPS 204
- FIPS 205
- NIST IR 8547 initial public draft page
- NIST post-quantum cryptography project page
- NIST post-quantum cryptography FAQ
- NIST SP 800-63B-4 status page
- NIST SP 800-63B-4 text
- Mozilla enterprise policy reference
- Chromium commit enabling ML-KEM on all platforms
- Yubico WebAuthn algorithms guide
- RFC 9106 (Argon2), Informational
- OWASP Password Storage Cheat Sheet
- IETF draft: ML-DSA for WebAuthn

About the author

Scott A. Cole is an AI strategy consultant and author in Capitola, California. He has more than 25 years in enterprise software, AI and machine learning, and business ownership. His career began in anti-virus research at McAfee. He holds MBAs from Columbia and UC Berkeley Haas and a computer science degree from UC Davis.

Today he builds and tests multi-agent systems on local models, including work that measures how often small models accept forged policy documents and what each defense costs. He is the author of more than 30 books, including the Stop Learning AI series for executives.